

CYBERSECURITY ANALYST PORTFOLIO CASE STUDY

Apache Vulnerability Assessment and Remediation

Nikto scanning, manual validation, Apache hardening, post-remediation verification, and evidence integrity

RYAN BRYANT | SOC / CYBERSECURITY ANALYST CANDIDATE | AUGUST 2026

OUTCOME Assessed one authorized Ubuntu Apache server, validated scanner findings, implemented targeted hardening, reduced Nikto-reported items from 10 to 4, preserved service availability, and hashed five evidence files.

Component	Address / role	Control
Parrot Security 7.3	10.10.10.5 - assessment workstation	Nikto 2.6.0 and curl
Ubuntu Server 24.04	10.10.10.4 - authorized target	Apache 2.4.58 Ubuntu package
SOC-Lab	10.10.10.0/24 isolated NAT network	No public or production target

Authorized local simulation only. No external system was targeted. AI assistance is disclosed in this report.

1. Executive Summary

I performed a controlled web-server vulnerability assessment from Parrot Security against LINUX-WEBSERVER01, an Ubuntu VM at 10.10.10.4. A pre-scan HTTP baseline confirmed Apache/2.4.58 and exposed an inode-bearing ETag. Nikto 2.6.0 issued 8,053 HTTP requests and reported ten items, primarily response-header and information-disclosure observations.

I manually validated the allowed HTTP methods and checked the installed Ubuntu Apache package against its candidate version. The host had the current repository candidate, so Nikto's generic upstream-version warning was not accepted as a confirmed vulnerability. I then enabled mod_headers and deployed a reversible Apache hardening configuration that hid the precise version, removed ETag, and added four browser security headers. Apache passed configtest, reloaded successfully, and continued returning HTTP 200.

The post-remediation Nikto scan reported four items, a 60% reduction. Manual validation demonstrated that one remaining X-Content-Type-Options result was a scanner false negative, one HSTS result was not applicable to the HTTP-only lab, the methods finding was informational, and CSP frame-ancestors addressed the framing-control concern. No exploitation or evidence of compromise was observed.

Metric	Before	After	Analyst conclusion
Nikto reported items	10	4	60% reduction
Server banner	Apache/2.4.58 (Ubuntu)	Apache	Version disclosure reduced
ETag	Inode-bearing value	Absent	Information leak removed
Security headers	Key controls missing	Four controls present	Manually confirmed
Availability	HTTP 200	HTTP 200	Service preserved

2. Objectives

- Define a one-host authorized assessment scope.
- Capture a reproducible pre-scan baseline.
- Identify web-server weaknesses with Nikto and validate them manually.
- Implement safe and reversible Apache hardening.
- Retest after remediation and preserve evidence with SHA-256 hashes.

3. Scope and Safety Controls

Control	Implementation
Authorization	Ryan Bryant's owned Ubuntu VM only
Target	http://10.10.10.4 on the isolated SOC-Lab network
Scanner	Parrot Security at 10.10.10.5
Technique	Non-authenticated Nikto web-server assessment
Excluded activity	No exploitation, brute force, denial of service, or public scanning
Change safety	New conf-available file, configtest, then graceful reload

Control	Implementation
Evidence path	~/SOC-Labs/Vulnerability-Assessment

4. Assessment Workflow

01 READINESS

Verified target reachability, created the evidence directory, and confirmed Nikto 2.6.0.

02 BASELINE

Captured HTTP status, Apache banner, ETag, and response headers before scanning.

03 INITIAL SCAN

Ran Nikto against the authorized HTTP service and saved text output.

04 VALIDATION

Checked Ubuntu package state and manually requested OPTIONS to classify methods.

05 REMEDIATION

Enabled mod_headers and deployed security headers, banner reduction, and ETag removal.

06 SAFE CHANGE CONTROL

Ran apache2ctl configtest before reload and verified the service remained active.

07 POST-CHANGE TEST

Confirmed HTTP 200 and all intended response headers from the assessment VM.

08 RESCAN

Repeated the same Nikto assessment and compared the reported-item count.

09 EVIDENCE INTEGRITY

Generated SHA-256 hashes for five text evidence files.

5. Key Commands

```
curl -sSI http://10.10.10.4/
nikto -h http://10.10.10.4 -output 02-nikto-scan.txt -Format txt
apt-cache policy apache2
curl -si -X OPTIONS http://10.10.10.4/
sudo a2enmod headers; sudo a2enconf soc-lab-hardening
sudo apache2ctl configtest; sudo systemctl reload apache2
sha256sum 01-http-baseline-headers.txt ... 05-nikto-post-remediation.txt
```

SAFETY BOUNDARY All scan traffic and configuration changes were limited to one owned VM. The hardening was validated before reload and did not interrupt the Apache service.

6. Evidence: Baseline and Initial Assessment

```

[user@parrot]~$ curl -sSI http://10.10.10.4/ | tee ~/SOC-Labs/Vulnerability-Assessment/01-http-baseline-headers.txt
HTTP/1.1 200 OK
Date: Sun, 23 Aug 2026 16:20:27 GMT
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Wed, 19 Aug 2026 19:34:52 GMT
ETag: "29af-6596b7f48ff74"
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html

[user@parrot]~$

```

Figure 1. Pre-scan HTTP 200 baseline exposed Apache/2.4.58 and an inode-bearing ETag.

```

[user@parrot]~$ nikto -h http://10.10.10.4 -output ~/SOC-Labs/Vulnerability-Assessment/02-nikto-scan.txt
Nikto v2.6.0
-----
+ Target IP: 10.10.10.4
+ Target Hostname: 10.10.10.4
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-08-23 16:22:18 (GMT0)
-----
+ Server: Apache/2.4.58 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29af, size: 6596b7f48ff74, mt
ime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/doc
s/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org
/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/e
n-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en
-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/
docs/Web/HTTP/Headers/Permissions-Policy
+ [600050] Apache/2.4.58 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP head
er with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Header
s/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the cont
ent of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-sca
ner/vulnerabilities/missing-content-type-header/
+ 8053 requests: 16 errors and 10 items reported on the remote host
+ End Time: 2026-08-23 16:27:59 (GMT0) (341 seconds)
-----
+ 1 host(s) tested
[user@parrot]~$

```

Figure 2. Initial Nikto scan completed 8,053 requests and reported ten items.

7. Initial Findings and Triage

Initial finding	Classification	Validation / rationale
Precise Apache banner	Low	Confirmed in baseline; useful for attacker research
Inode-bearing ETag	Low	Confirmed; unnecessary file metadata disclosure
Missing Referrer-Policy	Low hardening	Confirmed absent
Missing Content-Security-Policy	Low hardening	Confirmed absent
Missing X-Content-Type-Options	Low hardening	Confirmed absent
Missing Permissions-Policy	Low hardening	Confirmed absent
Missing HSTS	Not applicable	HTTP-only lab; HSTS is meaningful with HTTPS
Apache appears outdated	Not confirmed	Installed package equaled Ubuntu repository candidate
GET/HEAD/POST/OPTIONS allowed	Informational	No PUT, DELETE, or TRACE observed
Framing protection	Low hardening	Addressed with CSP frame-ancestors

8. Evidence: Manual Validation

```
socstudent@linux-webserver01:~$ apt-cache policy apache2
apache2:
  Installed: 2.4.58-1ubuntu8.15
  Candidate: 2.4.58-1ubuntu8.15
  Version table:
 *** 2.4.58-1ubuntu8.15 500
      500 http://us.archive.ubuntu.com/ubuntu noble-updates/main amd64 Packages
      500 http://security.ubuntu.com/ubuntu noble-security/main amd64 Packages
      100 /var/lib/dpkg/status
 2.4.58-1ubuntu8 500
      500 http://us.archive.ubuntu.com/ubuntu noble/main amd64 Packages
N: Ignoring file 'wauh.list.disable' in directory '/etc/apt/sources.list.d/' as it has an invalid filename extension
socstudent@linux-webserver01:~$ apt list --upgradable 2>/dev/null | grep '^apache2/' || echo "Apache is not listed for upgrade"
Apache is not listed for upgrade
socstudent@linux-webserver01:~$
```

Figure 3. Installed Apache package equaled the Ubuntu repository candidate and was not listed for upgrade.

```
[user@parrot]~$ curl -si -X OPTIONS http://10.10.10.4/ | tee ~/SOC-Labs/Vulnerability-Assessment/03-http-options-validation.txt
HTTP/1.1 200 OK
Date: Sun, 23 Aug 2026 16:35:57 GMT
Server: Apache/2.4.58 (Ubuntu)
Allow: POST,OPTIONS,HEAD,GET
Content-Length: 0
Content-Type: text/html

[user@parrot]~$
```

Figure 4. Manual OPTIONS request confirmed only GET, HEAD, POST, and OPTIONS.

ANALYST JUDGMENT Nikto's upstream-version comparison was not treated as proof that the Ubuntu package was vulnerable. Repository state and vendor security maintenance must be considered before assigning risk.

9. Remediation Implemented

Control	Apache directive / header	Security purpose
Banner reduction	ServerTokens Prod; ServerSignature Off	Reduces precise version disclosure
ETag removal	FileETag None; Header always unset ETag	Removes inode/file metadata exposure
MIME protection	X-Content-Type-Options: nosniff	Restricts content-type sniffing
Referrer control	Referrer-Policy: strict-origin-when-cross-origin	Limits cross-origin referrer detail
Content restrictions	Content-Security-Policy	Constrains content, objects, framing, and base URI
Browser features	Permissions-Policy	Disables geolocation, microphone, and camera
HSTS	Not deployed	Correctly deferred until HTTPS is configured

```
socstudent@linux-webserver01:~$ sudo apache2ctl configtest
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress th
is message
Syntax OK
socstudent@linux-webserver01:~$
```

Figure 5. Apache configuration validation returned Syntax OK.

```
socstudent@linux-webserver01:~$ sudo a2enconf soc-lab-hardening
Enabling conf soc-lab-hardening.
To activate the new configuration, you need to run:
systemctl reload apache2
socstudent@linux-webserver01:~$ sudo apac2ctl configtest
sudo: apac2ctl: command not found
socstudent@linux-webserver01:~$ sudo apache2ctl configtest
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress th
is message
Syntax OK
socstudent@linux-webserver01:~$ sudo systemctl reload apache2
socstudent@linux-webserver01:~$ sudo systemctl is-active apache2
active
socstudent@linux-webserver01:~$
```

Figure 6. Hardening configuration enabled, graceful reload completed, and Apache remained active.

10. Evidence: Post-Remediation Validation

```
[user@parrot]~]
$ curl -sSI -o ~/SOC-Labs/Vulnerability-Assessment/04-post-remediation-headers.txt http://10.10.10.4/
[user@parrot]~]
$ cat ~/SOC-Labs/Vulnerability-Assessment/04-post-remediation-headers.txt
HTTP/1.1 200 OK
Date: Sun, 23 Aug 2026 17:01:26 GMT
Server: Apache
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Content-Security-Policy: default-src 'self' 'unsafe-inline'; object-src 'none'; frame-ancestors 'none'; base-uri 'self'
Permissions-Policy: geolocation=(), microphone=(), camera=()
Last-Modified: Wed, 19 Aug 2026 19:34:52 GMT
Accept-Ranges: bytes
Content-Length: 10671
Vary: Accept-Encoding
Content-Type: text/html

[user@parrot]~]
$
```

Figure 7. HTTP 200 was preserved; version hidden, ETag absent, and four security headers present.

```
[user@parrot]~]
$ nikto -h http://10.10.10.4 -output ~/SOC-Labs/Vulnerability-Assessment/05-nikto-post-remediation.txt -Format txt
- Nikto v2.6.0

-----
+ Target IP:          10.10.10.4
+ Target Hostname:    10.10.10.4
+ Target Port:        80
+ Platform:           Linux/Unix
+ Start Time:         2026-08-23 17:05:04 (GMT0)
-----
+ Server: Apache
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8053 requests: 16 errors and 4 items reported on the remote host
+ End Time:          2026-08-23 17:10:45 (GMT0) (341 seconds)
-----
+ 1 host(s) tested
[user@parrot]~]
$
```

Figure 8. Post-remediation Nikto scan reported four items, down from ten.

11. Post-Remediation Analysis

Remaining Nikto item	Disposition	Basis
HSTS missing	Accepted / not applicable	Target serves HTTP; deploy after HTTPS
Allowed methods	Informational	No dangerous modification or TRACE methods
X-Frame-Options message	Mitigated	CSP frame-ancestors 'none' is present
X-Content-Type-Options missing	Scanner false negative	Manual response shows nosniff
16 scan errors	Limitation	Count remained unchanged; no finding was inferred solely from errors

MEASURED RESULT Reported items fell from 10 to 4. Manual evidence further reduced the unresolved security concern count by showing one false negative, one not-applicable result, and two informational or mitigated observations.

12. Evidence Integrity

```
[user@parrot]--[~/SOC-Labs/Vulnerability-Assessment]
$sha256sum 01-http-baseline-headers.txt 02-nikto-scan.txt 03-http-options-validation.txt 04-post-remediation-headers.txt 05-nikto-post-remediation.txt | tee SHA256SUMS.txt
189b07022af06db21a644054eb5d5c1bc747e0738d3f8bed84b9949bc58d4fbc 01-http-baseline-headers.txt
ecd980814ff671ff9b9457922f6318d45d1238b6d1c348ece3134ca0eb3a55ce 02-nikto-scan.txt
81a1eeb1c654aa94a378feacf3afc20d2b6db3af6e6509442460f4fd494f5cc1 03-http-options-validation.txt
e3ab41e7660c1a6307236e07ce5bad7d51365367ba8bf99186a735cb846d7386 04-post-remediation-headers.txt
47e637608c480ba404b138c34146ee0e4f9649e88e09639d755958840dead7cf 05-nikto-post-remediation.txt
[user@parrot]--[~/SOC-Labs/Vulnerability-Assessment]
$cat SHA256SUMS.txt
189b07022af06db21a644054eb5d5c1bc747e0738d3f8bed84b9949bc58d4fbc 01-http-baseline-headers.txt
ecd980814ff671ff9b9457922f6318d45d1238b6d1c348ece3134ca0eb3a55ce 02-nikto-scan.txt
81a1eeb1c654aa94a378feacf3afc20d2b6db3af6e6509442460f4fd494f5cc1 03-http-options-validation.txt
e3ab41e7660c1a6307236e07ce5bad7d51365367ba8bf99186a735cb846d7386 04-post-remediation-headers.txt
47e637608c480ba404b138c34146ee0e4f9649e88e09639d755958840dead7cf 05-nikto-post-remediation.txt
[user@parrot]--[~/SOC-Labs/Vulnerability-Assessment]
$
```

Figure 9. SHA-256 manifest for all five assessment evidence files.

The manifest allows a reviewer to recalculate each hash and detect later changes to the baseline, scan, validation, or post-remediation evidence.

13. Risk Summary and Recommendations

Area	Final risk	Recommended next action
Browser security headers	Reduced	Retain and tune CSP for the deployed application
Version disclosure	Reduced	Keep ServerTokens Prod and monitor Ubuntu security notices
ETag metadata	Resolved	Retain ETag suppression unless application caching requires a reviewed alternative
Transport security	Open improvement	Deploy TLS, redirect HTTP, then enable HSTS
HTTP methods	Low / informational	Restrict POST or OPTIONS only if the application does not need them
Scanner limitations	Managed	Continue manual validation and authenticated testing where appropriate

14. Skills Demonstrated

- Authorized vulnerability-assessment scoping
- Nikto web-server scanning and evidence preservation
- HTTP header and method analysis with curl
- False-positive and false-negative validation
- Ubuntu package-state interpretation
- Apache module and configuration hardening
- Safe change validation and graceful service reload
- Before-and-after measurement and SHA-256 evidence integrity
- Employer-facing technical documentation

15. Employer-Facing Project Summary

RESUME BULLET Conducted an authorized Nikto assessment of an isolated Ubuntu Apache server; manually validated scanner results, implemented reversible header and metadata hardening, reduced reported items by 60%, preserved HTTP availability, and hashed five evidence files for integrity.

Interview talking points

- Why an automated version warning was not accepted without Ubuntu package validation.
- How manual curl evidence revealed a post-scan false negative.
- Why HSTS was deferred on an HTTP-only service.
- How configtest and graceful reload reduced remediation risk.

16. Assistance and Source Transparency

This project was completed by Ryan Bryant in his personal home lab with assistance from OpenAI ChatGPT (Sarah). ChatGPT helped plan the authorized workflow, troubleshoot commands, interpret scanner output, identify validation steps, locate official documentation, and organize this report. Ryan personally operated the VMs, entered the commands, ran the tools, changed and validated Apache configuration, captured the evidence, and reviewed the conclusions. ChatGPT did not independently access or operate the lab computer.

17. References and Validation Sources

[Nikto official project](#). Tool purpose, usage, and output behavior.

[CIRT Nikto project page](#). Official description of server checks and misconfiguration detection.

[Apache mod_headers documentation](#). Header directive behavior and configuration.

[Apache FileETag directive](#). Official definition of ETag file attributes.

[Apache ServerTokens directive](#). Official banner-detail control.

[Ubuntu Security Notices](#). Vendor source for security fixes in official Ubuntu packages.

FINAL DISPOSITION Authorized vulnerability assessment and remediation completed. Hardening controls were applied safely, reported items were reduced by 60%, service availability was preserved, and remaining scanner output was manually dispositioned.